

Web Investigation

Exercise: 1.3 | Remote File Inclusion Activity detected

Objectives:

The primary objective is to conduct a thorough investigation into a suspected Remote File Inclusion Incident with the goal of identifying the source, scope, and impact of the attack.

Incident Details:

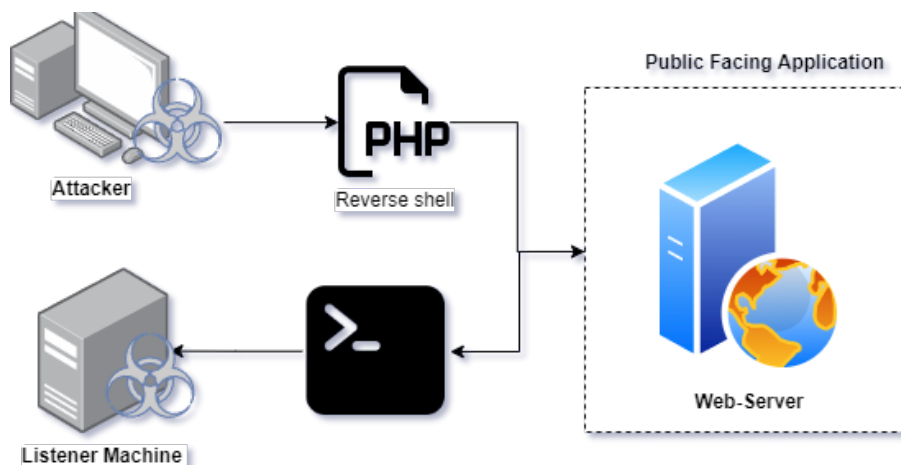
Investigate the suspicious RFI activity detected by the security monitoring systems. Investigate the web logs to identify the targeted IP, source, and potential impact.

Targeted URL:

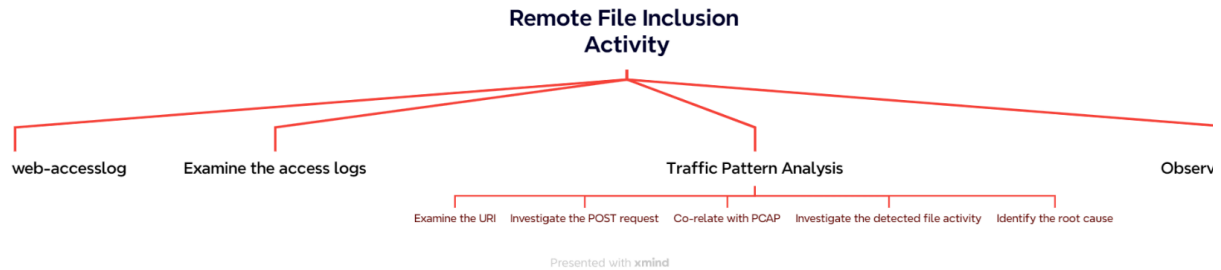
`http://192.168.117.190/prod/vulnerabilities/upload/`

About RFI:

RFI is a type of web-based security vulnerability exploit that occurs when an attacker is able to upload suspected files including php, ps1, exe, ddl etc directly into the web server. This can happen when the upload function of a web application has not been properly sanitised, by exploiting such a vulnerability the attacker can directly deploy the payload and gain a stable shell with the targeted web server.



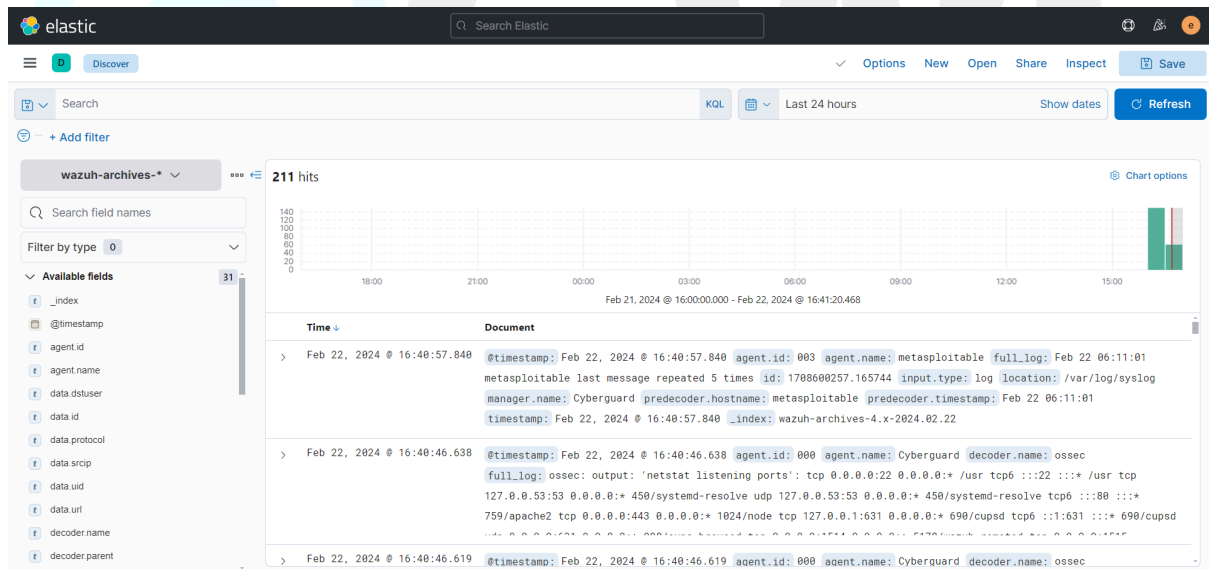
Investigation Mindmap:



Step:01

The first step of the investigation begins by analysing the web server logs. In our Blue Team Infrastructure, as we integrated the web log with our SIEM Wazuh : ELK solutions

Open the SIEM Console and navigate to the Analytics → Discover section



The screenshot shows the Elastic SIEM console interface. The top navigation bar includes the Elastic logo, a search bar, and various icons. The main section is titled 'Discover' and shows a search for 'wazuh-archives-*' with 211 hits. The left sidebar contains a list of available fields, including @timestamp, agent.id, agent.name, data.dstuser, data.id, data.protocol, data.scrip, data.uid, data.url, decoder.name, and decoder.parent. The main content area displays a timeline view of the search results, with a document preview showing details for a specific event, including timestamps, agent information, and log data.

Note: Make sure that your are under **wazuh–archives** index

Step:03

Investigating XSS involves careful steps to ensure security and determine the nature and potential threats associated with the web logs.

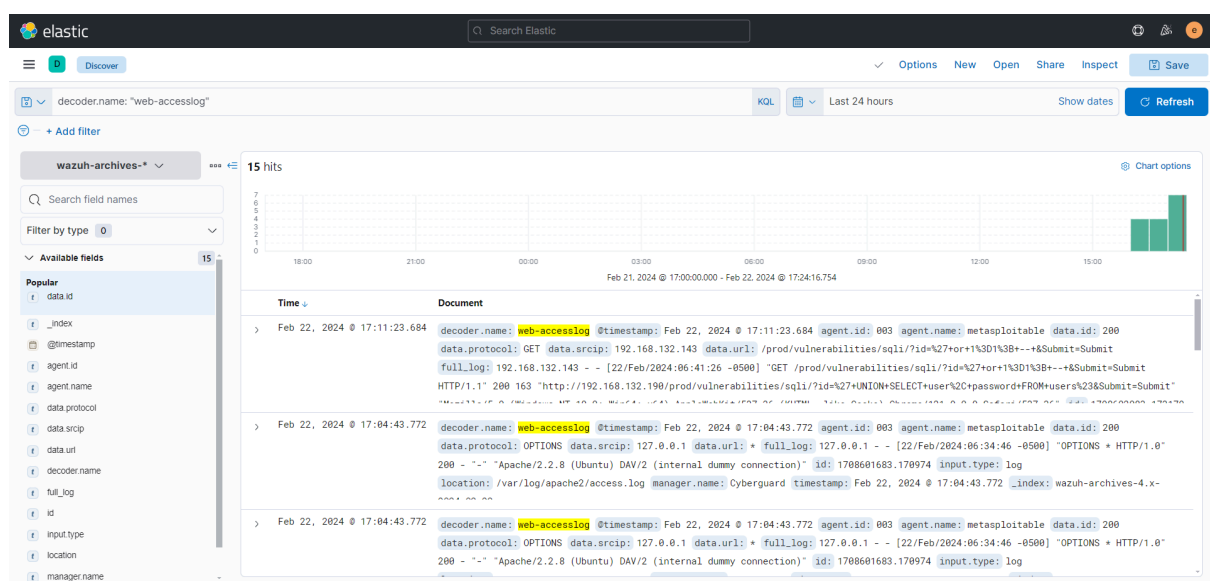
1. Retrieving the web-accesslog : decoder
2. Examine the access logs
3. Traffic Pattern Analysis
 - a. Examine the URI
 - b. Investigate the POST request
 - c. Co-relate with PCAP
 - d. Investigate the detected file activity
 - e. Identify the root cause
4. Observe the findings

Retrieving the web-accesslog

Identifying and collecting the web access log allows us to extract certain logs for additional investigation.

Use the following command to obtain the web-access log.

```
Unset
decoder.name: "web-accesslog"
```



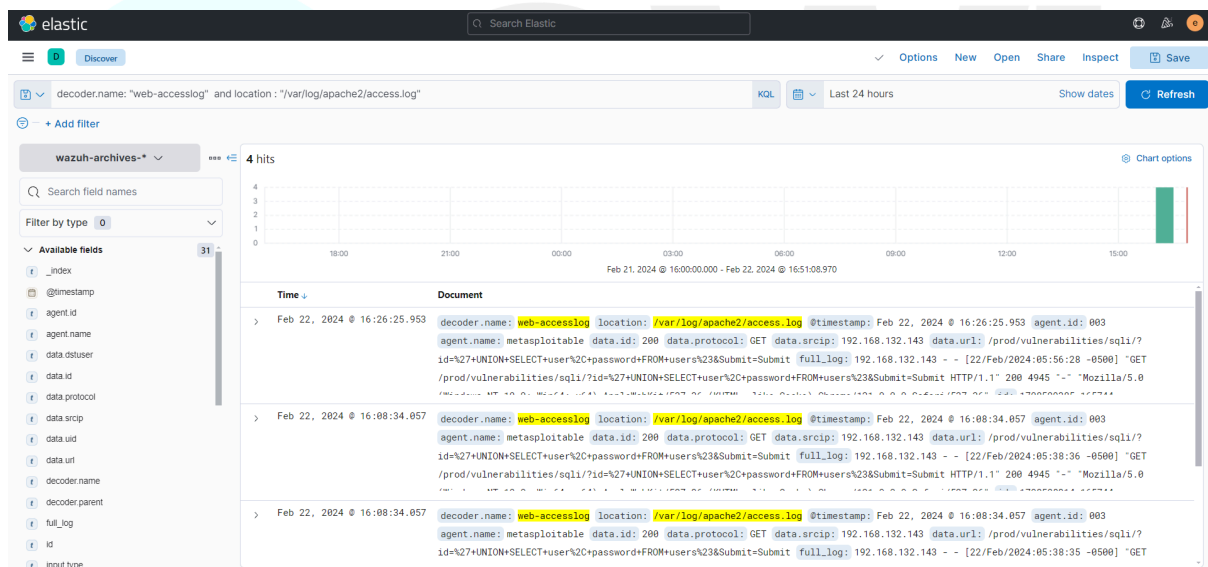
Decoders are the key components which are responsible for parsing raw logs into a structured format that can be easily analysed and understood by the system.

Examine the access logs

In general web server logs contain valuable information about incoming requests, errors, and server activities. It is recommended to check the access logs which record every request made to the server.

Unset

```
decoder.name: "web-accesslog" and location: "/var/log/apache2/access.log"
```



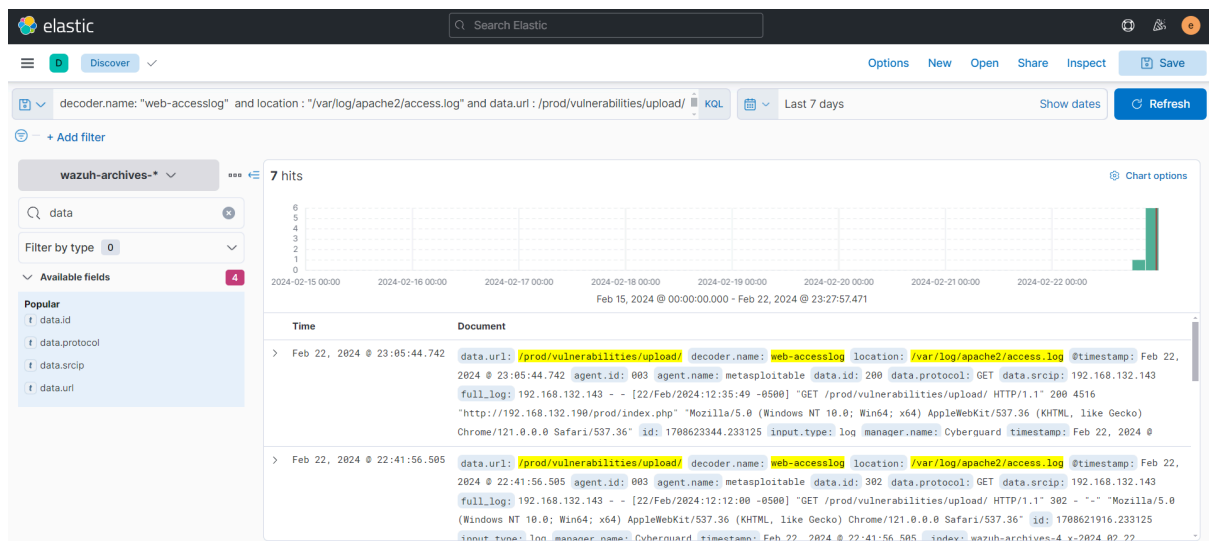
Note: Access logs provide details like IP addresses, requested files, status codes, etc.

Examine the URL

The next step is to observe the activity which is associated with the detected URL, Execute the below command and observe the findings.

Unset

```
decoder.name: "web-accesslog" and location : "/var/log/apache2/access.log"
and data.url : /prod/vulnerabilities/upload/
```

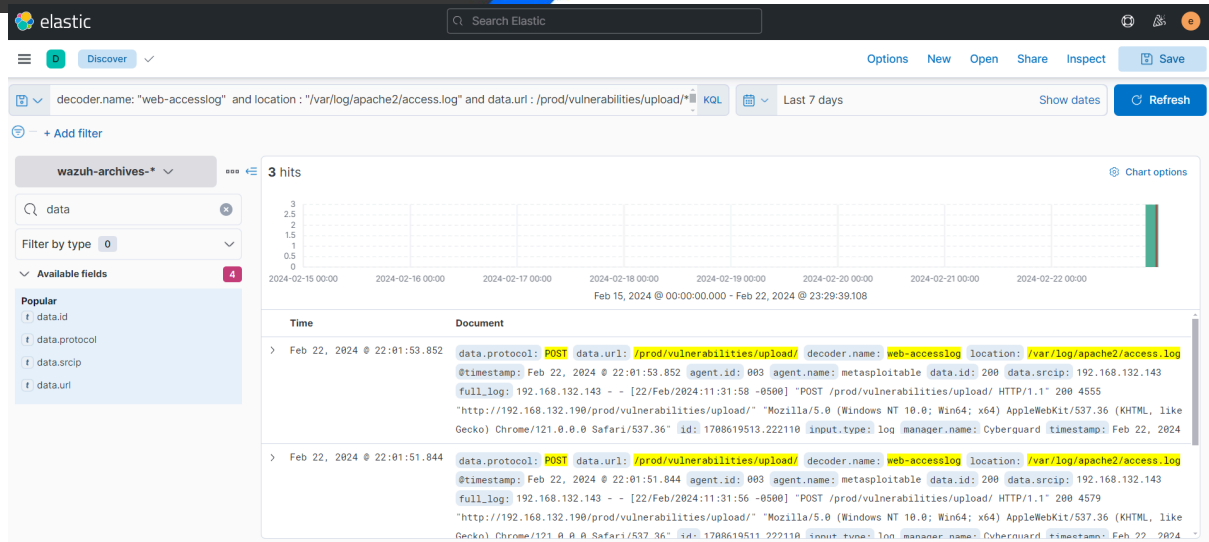


Investigate the POST request

Generally, an HTTP **POST** request is used during the file upload process on a web application.

Unset

```
decoder.name: "web-accesslog" and location : "/var/log/apache2/access.log"
and data.url : /prod/vulnerabilities/upload/* and data.protocol : "POST"
```



Co-relate with PCAP

In-general **POST** request doesn't provide a high visibility, in such it is recommend to correlate with network traffic, in our scenarios we have attached the PCAP file of the specific activity named: **suspected.pcapng**

Wireshark is a popular and powerful open-source network protocol analyzer. It allows you to capture and inspect the data travelling back and forth on a network in real-time or from a previously recorded file. Wireshark supports a wide range of protocols and provides detailed information about the packets exchanged between devices on a network.

Execute the below mentioned command over the wireshark to specifically filterout detected src IP activity

```
Unset
ip.addr == 192.168.132.143
```

No.	Time	Source	Destination	Protocol	Src Port	Dest Port	Length	Info
4	0.000992521	192.168.132.143	192.168.132.190	TCP	50399 80	60 50399	80	60 50399 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
6	0.001008122	192.168.132.143	192.168.132.190	TCP	50399 80	50399 80	80	60 50398 → 80 [ACK] Seq=1 Ack=1 Win=513 Len=0
8	0.001311070	192.168.132.143	192.168.132.190	TCP	50399 80	50399 80	80	60 50398 → 80 [ACK] Seq=1 Ack=1 Win=51328 Len=0
13	2.562092083	192.168.132.143	192.168.132.190	HTTP	50399 80	50399 80	80	605 Get /prod/hackable/uploads/rev.php HTTP/1.1
21	2.614884198	192.168.132.143	192.168.132.190	TCP	50399 80	60 50398	80	60 50398 → 80 [ACK] Seq=552 Ack=386 Win=513 Len=0
23	3.798577592	192.168.132.143	192.168.132.190	TCP	50399 80	66 [TCP Dup ACK #B1] 50399 → 80 [ACK] Seq=1 Ack=1 Win=131328 Len=0		
24	6.866640187	192.168.132.143	192.168.132.255	DB-LS-DISC/JSON	17500 17500	176	Dropbox LAN sync Discovery Protocol, JavaScript Object Notation	
30	7.385517577	192.168.132.143	192.168.132.190	TCP	50399 80	60 50398	80	60 50398 → 80 [ACK] Seq=552 Ack=332 Win=511 Len=0
33	9.799206588	192.168.132.143	192.168.132.190	TCP	50399 80	66 [TCP Dup ACK #B2] 50399 → 80 [ACK] Seq=1 Ack=1 Win=131328 Len=0		
38	9.919031235	192.168.132.143	192.168.132.190	TCP	50399 80	60 50398	80	60 50398 → 80 [ACK] Seq=552 Ack=366 Win=511 Len=0
47	14.135841075	192.168.132.143	192.168.132.190	TCP	50399 80	60 50398	80	60 50398 → 80 [ACK] Seq=552 Ack=428 Win=511 Len=0
53	16.967244409	192.168.132.143	192.168.132.190	TCP	50399 80	60 50398	80	60 50398 → 80 [ACK] Seq=552 Ack=1101 Win=508 Len=0
55	18.554114278	192.168.132.143	192.168.132.226	TCP	50290 443	60 50290	443	60 50290 → 443 [ACK] Seq=1 Ack=1 Win=4098 Len=1 [TCP segment of a re
63	21.621908443	192.168.132.143	192.168.132.190	TCP	50399 80	60 50398	80	60 50398 → 80 [ACK] Seq=552 Ack=1118 Win=508 Len=0
70	21.641421969	192.168.132.143	192.168.132.190	TCP	50399 80	60 50398	80	60 50398 → 80 [ACK] Seq=552 Ack=2706 Win=513 Len=0
73	21.801182846	192.168.132.143	192.168.132.190	TCP	50399 80	66 [TCP Dup ACK #B3] 50399 → 80 [ACK] Seq=1 Ack=1 Win=131328 Len=0		
83	25.287778260	192.168.132.143	192.168.132.190	TCP	50399 80	60 50398	80	60 50398 → 80 [ACK] Seq=552 Ack=2771 Win=513 Len=0
86	25.330190669	192.168.132.143	192.168.132.190	TCP	50399 80	60 50398	80	60 50398 → 80 [ACK] Seq=552 Ack=2776 Win=513 Len=0
92	29.879434897	192.168.132.143	192.168.132.226	TLSv1.2	50290 443	1514	Ignored Unknown Record	
94	29.879552365	192.168.132.143	192.168.132.226	TLSv1.2	50290 443	207	Ignored Unknown Record	
96	29.879600778	192.168.132.143	192.168.132.226	TLSv1.2	50290 443	237	Application Data	
99	30.706148881	192.168.132.143	192.168.132.226	TCP	50290 443	60 50290	443	60 50290 → 443 [ACK] Seq=1798 Ack=600 Win=4095 Len=0
95	0.001006779	192.168.132.190	192.168.132.143	TCP	80 50398	66 80	50398	66 80 → 50398 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PE
7	0.001018326	192.168.132.190	192.168.132.143	TCP	80 50399	66 80	50399	66 80 → 50399 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PE
14	2.562269178	192.168.132.190	192.168.132.143	TCP	80 50398	66 80	50398	66 80 → 50398 [ACK] Seq=1 Ack=552 Win=6944 Len=0
16	2.574232197	192.168.132.190	192.168.132.143	TCP	80 50398	359 80	50398	66 80 → 50398 [PSH, ACK] Seq=1 Ack=552 Win=6944 Len=305 [TCP segmen
22	3.798566911	192.168.132.190	192.168.132.143	TCP	80 50399	66 [TCP Retransmission] 80 → 50399 [SYN, ACK] Seq=0 Ack=1 Win=5840		
27	7.384566010	192.168.132.190	192.168.132.143	TCP	80 50398	66 80 → 50398 [PSH, ACK] Seq=386 Ack=552 Win=6944 Len=12 [TCP segmen		
29	7.385516234	192.168.132.190	192.168.132.143	TCP	80 50398	66 80 → 50398 [PSH, ACK] Seq=386 Ack=552 Win=6944 Len=12 [TCP segmen		
32	9.799196819	192.168.132.190	192.168.132.143	TCP	80 50399	66 [TCP Retransmission] 80 → 50399 [SYN, ACK] Seq=0 Ack=1 Win=5840		
35	9.918612383	192.168.132.190	192.168.132.143	TCP	80 50398	66 80 → 50398 [PSH, ACK] Seq=332 Ack=552 Win=6944 Len=14 [TCP segmen		
37	9.918864381	192.168.132.190	192.168.132.143	TCP	80 50398	74 80 → 50398 [PSH, ACK] Seq=346 Ack=552 Win=6944 Len=20 [TCP segmen		
44	14.135230678	192.168.132.190	192.168.132.143	TCP	80 50398	66 80 → 50398 [PSH, ACK] Seq=366 Ack=552 Win=6944 Len=14 [TCP segmen		
46	14.135568394	192.168.132.190	192.168.132.143	TCP	80 50398	102 80 → 50398 [PSH, ACK] Seq=380 Ack=552 Win=6944 Len=48 [TCP segmen		

For the above result we identified that the src has been try access the url
/prod/hackable/uploads/rev[.]php

Investigate the detected file activity

The next step is to attempt to get the detected information via the SIEM console after identifying the file, which is advised to be redirected to. Execute the below mentioned command and observe the result

Unset

```
decoder.name: "web-accesslog" and location : "/var/log/apache2/access.log"
and data.protocol : "GET" and data.url : "/prod/hackable/uploads/rev.php"
```

elastic

Search Elastic

Discover

Options New Open Share Inspect Save

decoder.name: "web-accesslog" and location: "/var/log/apache2/access.log" and data.protocol: "GET" and data.url: "/pro

KQL

Last 7 days

Show dates

Refresh

+ Add filter

wazuh-archives-*

2 hits

Chart options

data

Filter by type 0

Available fields 4

Popular

f data.id

f data.protocol

f data.scrip

f data.url

2 hits

2

1.5

1

0.5

0

2024-02-15 00:00

2024-02-16 00:00

2024-02-17 00:00

2024-02-18 00:00

2024-02-19 00:00

2024-02-20 00:00

2024-02-21 00:00

2024-02-22 00:00

Feb 15, 2024 @ 00:00:00.000 - Feb 22, 2024 @ 23:36:44.159

Time

Document

> Feb 22, 2024 @ 22:05:43.891

data.protocol: GET

data.url: /prod/hackable/uploads/rev.php

decoder.name: web-accesslog

location: /var/log/apache2/access.log

@timestamp: Feb 22, 2024 @ 22:05:43.891

agent.id: 003

agent.name: metasploitable

data.id: 200

data.scrip: 192.168.132.143

full.log: 192.168.132.143 - - [22/Feb/2024:11:35:26 -0500] "GET /prod/hackable/uploads/rev.php HTTP/1.1" 200 2451 "-"

Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36

id: 1708619743.226955

input.type: log

manager.name: Cyberguard

timestamp: Feb 22, 2024 @ 22:05:43.891

index: wazuh-archives-

> Feb 22, 2024 @ 22:02:47.854

data.protocol: GET

data.url: /prod/hackable/uploads/rev.php

decoder.name: web-accesslog

location: /var/log/apache2/access.log

@timestamp: Feb 22, 2024 @ 22:02:47.854

agent.id: 003

agent.name: metasploitable

data.id: 200

data.scrip: 192.168.132.143

full.log: 192.168.132.143 - - [22/Feb/2024:11:32:45 -0500] "GET /prod/hackable/uploads/rev.php HTTP/1.1" 200 129 "-"

Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36

id: 1708619567.223118

input.type: log

manager.name: Cyberguard

timestamp: Feb 22, 2024 @ 22:02:47.854

index: wazuh-archives-

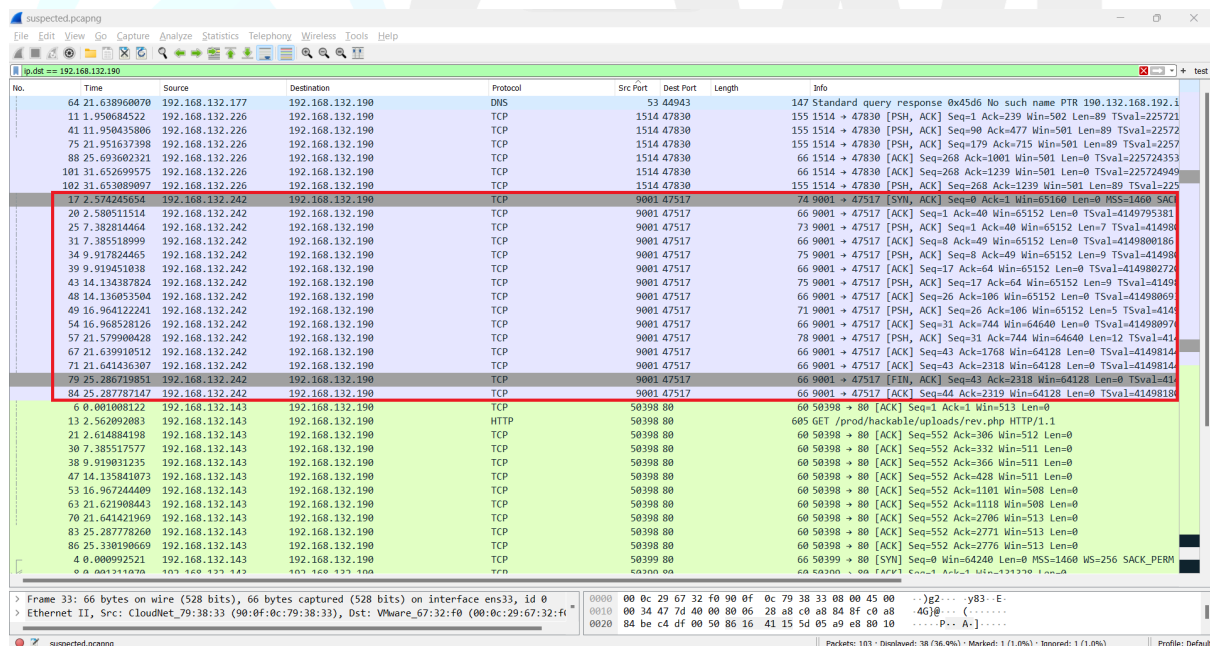
Identify the root cause

After gathering every possible information it's time to determine the root cause for the detected activity, typical RFI will maintain a stable shell with the attacker machine. To determine the particular activity again redirect to the **PCAP** file and execute the following command

```
Unset
ip.src == 192.168.117.190
```

We have simply keep the detected src as a destination to observe every incoming request,

In-real case scenarios the network traffic might be too hard to be prioritised due to its large network connectivity, in such cases it's recommended to check based on the suspected port based access. As per the observation over the PCAP we observed that the src is been trying to communicating to an suspected IP over the port **9001**



No.	Time	Source	Destination	Protocol	Src Port	Dest Port	Length	Info
64	21.638960070	192.168.132.177	192.168.132.190	DNS	53	44943	147	Standard query response 0x45d6 No such name PTR 190.132.168.192.i
11	1.950684522	192.168.132.226	192.168.132.190	TCP	1514	47830	155	1514 → 47830 [PSH, ACK] Seq=1 Ack=239 Win=502 Len=89 TSval=225721
41	11.950435806	192.168.132.226	192.168.132.190	TCP	1514	47830	155	1514 → 47830 [PSH, ACK] Seq=90 Ack=477 Win=501 Len=89 TSval=22572
75	21.951637398	192.168.132.226	192.168.132.190	TCP	1514	47830	155	1514 → 47830 [PSH, ACK] Seq=179 Ack=715 Win=501 Len=89 TSval=22572
88	25.693602321	192.168.132.226	192.168.132.190	TCP	1514	47830	66	1514 → 47830 [ACK] Seq=268 Ack=1001 Win=501 Len=0 TSval=225724353
101	31.652699575	192.168.132.226	192.168.132.190	TCP	1514	47830	66	1514 → 47830 [ACK] Seq=268 Ack=1239 Win=501 Len=0 TSval=225724049
102	31.653898997	192.168.132.226	192.168.132.190	TCP	1514	47830	155	1514 → 47830 [PSH, ACK] Seq=268 Ack=1239 Win=501 Len=89 TSval=225
17	2.574245654	192.168.132.242	192.168.132.190	TCP	9001	47517	74	9001 → 47517 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK
20	2.580511514	192.168.132.242	192.168.132.190	TCP	9001	47517	66	9001 → 47517 [ACK] Seq=1 Ack=40 Win=65152 Len=0 TSval=4149795381
25	7.382814464	192.168.132.242	192.168.132.190	TCP	9001	47517	73	9001 → 47517 [PSH, ACK] Seq=1 Ack=40 Win=65152 Len=7 TSval=414980
31	7.385518999	192.168.132.242	192.168.132.190	TCP	9001	47517	66	9001 → 47517 [ACK] Seq=8 Ack=49 Win=65152 Len=0 TSval=4149800186
34	9.917824465	192.168.132.242	192.168.132.190	TCP	9001	47517	75	9001 → 47517 [PSH, ACK] Seq=8 Ack=49 Win=65152 Len=9 TSval=414980
39	9.919581038	192.168.132.242	192.168.132.190	TCP	9001	47517	66	9001 → 47517 [ACK] Seq=17 Ack=64 Win=65152 Len=0 TSval=414980272
43	14.134387824	192.168.132.242	192.168.132.190	TCP	9001	47517	75	9001 → 47517 [PSH, ACK] Seq=17 Ack=64 Win=65152 Len=9 TSval=4149
48	14.136053504	192.168.132.242	192.168.132.190	TCP	9001	47517	66	9001 → 47517 [ACK] Seq=26 Ack=106 Win=65152 Len=0 TSval=41498069
49	16.964122241	192.168.132.242	192.168.132.190	TCP	9001	47517	71	9001 → 47517 [PSH, ACK] Seq=26 Ack=106 Win=65152 Len=5 TSval=414
54	16.968528126	192.168.132.242	192.168.132.190	TCP	9001	47517	66	9001 → 47517 [ACK] Seq=31 Ack=744 Win=64640 Len=0 TSval=41498097
57	21.579900428	192.168.132.242	192.168.132.190	TCP	9001	47517	78	9001 → 47517 [PSH, ACK] Seq=31 Ack=744 Win=64640 Len=12 TSval=41
67	21.639910512	192.168.132.242	192.168.132.190	TCP	9001	47517	66	9001 → 47517 [ACK] Seq=43 Ack=1768 Win=64128 Len=0 TSval=4149814
71	21.641436307	192.168.132.242	192.168.132.190	TCP	9001	47517	66	9001 → 47517 [ACK] Seq=43 Ack=2318 Win=64128 Len=0 TSval=4149814
79	25.280719851	192.168.132.242	192.168.132.190	TCP	9001	47517	66	9001 → 47517 [FIN, ACK] Seq=43 Ack=2318 Win=64128 Len=0 TSval=41
84	25.287787147	192.168.132.242	192.168.132.190	TCP	9001	47517	66	9001 → 47517 [ACK] Seq=44 Ack=2319 Win=64128 Len=0 TSval=4149818
6	0.001008122	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=1 Ack=1 Win=513 Len=0
13	2.562092083	192.168.132.143	192.168.132.190	HTTP	50398	80	605	GET /prod/hackable/uploads/rev.php HTTP/1.1
21	2.614884198	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=552 Ack=306 Win=512 Len=0
30	7.385517577	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=552 Ack=332 Win=511 Len=0
38	9.919031235	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=552 Ack=306 Win=511 Len=0
47	14.135841073	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=552 Ack=428 Win=511 Len=0
53	16.967244409	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=552 Ack=1101 Win=508 Len=0
63	21.621908443	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=552 Ack=1118 Win=508 Len=0
70	21.641421969	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=552 Ack=2706 Win=513 Len=0
83	25.287778260	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=552 Ack=2771 Win=513 Len=0
86	25.330190669	192.168.132.143	192.168.132.190	TCP	50398	80	60	50398 → 80 [ACK] Seq=552 Ack=2776 Win=513 Len=0
4	0.000992521	192.168.132.143	192.168.132.190	TCP	50399	80	66	50399 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM

Execute the below mentioned command to specifically filter out the suspected port activity

```
Unset
ip.dst == 192.168.117.190 && tcp.srcport ==9001
```

On further deep investigating the packet we identified multiple host command over the targeted web-server

```
Wireshark - Packet 34 - suspected.pcapng

> Frame 34: 75 bytes on wire (600 bits), 75 bytes captured (600 bits) on interface ens33, id 0
> Ethernet II, Src: PcsCompu_a6:97:86 (08:00:27:a6:97:86), Dst: VMware_67:32:f0 (00:0c:29:67:32:f0)
> Internet Protocol Version 4, Src: 192.168.132.242, Dst: 192.168.132.190
> Transmission Control Protocol, Src Port: 9001, Dst Port: 47517, Seq: 8, Ack: 49, Len: 9
> Data (9 bytes)

0000  00 0c 29 67 32 f0 08 00 27 a6 97 86 08 00 45 00  --)g2--- '-----E-
0010  00 3d d4 ad 40 00 40 06 db 0b c0 a8 84 f2 c0 a8  --=-@-@- -
0020  84 be 23 29 b9 9d df ea 64 b8 5e cb e4 f5 80 18  --#)-----d-^-----
0030  01 fd 36 70 00 00 01 01 08 0a f7 58 f6 de 00 01  --.6p-----X-----
0040  9e 2e 68 6f 73 74 6e 61 6d 65 0a                --.hostna me
```

```
Wireshark - Packet 43 - suspected.pcapng

> Frame 43: 75 bytes on wire (600 bits), 75 bytes captured (600 bits) on interface ens33, id 0
> Ethernet II, Src: PcsCompu_a6:97:86 (08:00:27:a6:97:86), Dst: VMware_67:32:f0 (00:0c:29:67:32:f0)
> Internet Protocol Version 4, Src: 192.168.132.242, Dst: 192.168.132.190
> Transmission Control Protocol, Src Port: 9001, Dst Port: 47517, Seq: 17, Ack: 64, Len: 9
> Data (9 bytes)

0000  00 0c 29 67 32 f0 08 00 27 a6 97 86 08 00 45 00  --)g2--- '-----E-
0010  00 3d d4 af 40 00 40 06 db 09 c0 a8 84 f2 c0 a8  --=-@-@- -
0020  84 be 23 29 b9 9d df ea 64 c1 5e cb e5 04 80 18  --#)-----d-^-----
0030  01 fd 37 ea 00 00 01 01 08 0a f7 59 07 56 00 01  --.7-----Y-V-
0040  9f 2b 69 66 63 6f 6e 66 69 67 0a                --.ifconf ig
```

Conclusion

The thorough examination of the incident has allowed you to understand the sequence of events leading up to the occurrence, identifying areas for improvement in processes and procedures.

Thank You!

Hope you have learnt a lot after practically completing

Blue Team Fundamentals Exercise.

If you like the investigation & the lab scenario,
feel free to tag us & share your achievement / progress
on social media platforms :)

For Enterprise Red Team / Blue Team / Purple Team

Cyber Range Labs / Training please email :

support@cyberwarfare.live

To know more visit at : <https://cyberwarfare.live>